Your First 30 Days

A practical plan for the month after the course: page 1 for you as an individual, by role; page 2 for a team standing up or improving its product security practice.

For everyone: about an hour a week

WEEK	FOCUS	DO THIS
1	**Find your channels**	Find your organization's internal channel for reporting a suspected product vulnerability, and who runs your PSIRT (product security incident response team). Find your company's published vulnerability disclosure policy. Save both where you can find them in a hurry. Can't find them? Raise it with your manager.
2	**Know one product**	Pick a product you work on. What does it connect to: an app, a cloud service, a hospital network, remote service access? Is it a cyber device? Does it have a software bill of materials (SBOM) and a threat model, and who owns them?
3	**Use the triggers**	Keep the engagement triggers in front of you: new interfaces or components, changes to security controls, new data or cloud services, customer security questions, suspected vulnerabilities, odd field behavior, end-of-support and remote access decisions. In one meeting, ask: *"Does this change how the product connects, what it trusts, or what data it holds?"*
4	**Make it a habit**	Pick one habit from your role below and keep it. Book 30 minutes with your product security team: what do they wish your role did more of? And when something might be a security problem, report it the same day. You don't need to be sure.

By role

Product owner or manager and program managers

- **WK 1** Find where security work sits in your roadmap: threat modeling, testing, SBOM, submission content.
- **WK 2** List end-of-support dates for your product and the platforms inside it, such as its operating system.
- **WK 3** Put security deliverables in the next release plan as real schedule items, with budget for postmarket updates.
- **WK 4** Agree with product security on the triggers your planning and design reviews will check.

Engineer software, firmware, systems, test

- **WK 1** Find your product's SBOM and compare it with what is actually in the build.
- **WK 2** Read the threat model or architecture views for the part you own. Ask about anything you don't recognize.
- **WK 3** Add the security question to your design and code review checklist; flag new interfaces and components.
- **WK 4** Hunt "temporary" back doors (debug ports, test accounts, default passwords); track or remove them.

Quality and regulatory

- **WK 1** Find where security lives in your quality system: design controls, risk management, supplier controls, complaints, CAPA.
- **WK 2** Check that security risks that could harm patients reach the safety risk file (ISO 14971, AAMI SW96).
- **WK 3** Add "Could this be security?" to complaint review, with a route to the PSIRT.
- **WK 4** Confirm which markets you sell in, which standards you declare, and who decides on regulator reporting for a vulnerability.

Customer-facing sales, service, support, clinical

- **WK 1** Find the approved security documentation for your products: MDS2 forms, security labeling, published advisories.
- **WK 2** Learn the route for customer security questionnaires, and how much time product security needs to answer.
- **WK 3** Rehearse the four moves for a reported vulnerability: report right away, don't investigate, preserve information, keep it confidential.
- **WK 4** Check how returned, demo and loaner units are wiped; they can hold network credentials or patient data.

For a team: stand up or improve your practice

For a product security lead, a quality or engineering manager, or anyone asked to get the practice started. Each week ends with something you can show. A small company can do this with two or three people; a large one should start with one product line.

WEEK	GOAL	WHAT TO DO	YOU'LL HAVE
1	**Find your reporting channel and PSIRT**	Trace how a suspected vulnerability reaches the right people: the internal channel, the published disclosure policy for outside researchers, who triages, and how complaints and service reports get routed. Send a test report and see how long it takes to land. If there is no PSIRT yet, name an interim owner.	A one-page "how to report" note that everyone can find
2	**Inventory products and SBOMs**	List the products on the market and in development. For each: what it connects to, whether it is a cyber device, where it is sold, whether an SBOM exists and is current, how its components are monitored for new vulnerabilities, and its end-of-support date.	A product inventory with gaps marked
3	**Add the engagement triggers to your process; draft your RACI**	Put the trigger list into design review checklists, change requests, complaint intake and supplier management. Then draft who is Responsible, Accountable (one role only), Consulted and Informed for each program activity, using the program RACI template. Look for activities with no accountable owner.	Updated checklists and a draft RACI with gaps marked
4	**Run a tabletop; assess maturity**	Run a 45 to 60 minute tabletop exercise with the scenario kit: an outside researcher reports a flaw, and the team works through the response as information arrives. Then score your program with the Product Security Maturity Framework scorecard and pick the top three improvements.	Tabletop findings with owners, a maturity baseline and a plan for next quarter

Templates and tools

- **Engagement checklist** (Word)
  `templates/engagement-checklist.docx`
- **Program RACI** (Excel, CSV)
  `templates/program-raci.xlsx`
- **Tabletop scenario kit** (Word)
  `templates/tabletop-scenario-kit.docx`
- **Product Security Maturity Framework scorecard**
  `mjhillyer.github.io/Product-Security-Maturity-Assessment-Program/scorecard.html`

Signs it's working

- [ ] Anyone on the team can say how to report a suspected vulnerability.
- [ ] Every product has an owner, a current SBOM and a known end-of-support date.
- [ ] Product security hears about changes at design review, not at release.
- [ ] Customer security questions get consistent answers from approved documents.
- [ ] The tabletop found gaps, and each gap has an owner and a date.

Common pitfalls

- Writing a big policy before anyone knows how to report a problem. Start with the channel.
- Treating the SBOM as a one-time submission document instead of a living list that drives vulnerability monitoring.
- Making product security accountable for everything. It guides and coordinates; product, engineering, quality and regulatory own their decisions.

When you need more

This guide accompanies the free course **Product Security in One Hour** (mjhillyer.github.io/Product-Security-in-One-Hour). For in-depth, instructor-led product security training for your teams, with exercises on your own products and MedTech regulatory depth, contact **Matt Hillyer LLC** at **matt@matthillyer.io**.